

INTERNAL PRIVACY & DATA-PROCESSING ADDENDUM

(DPA)

DRAFT — ATTORNEY REVIEW REQUIRED. Binds GetBriefed Inc/LLC internal operations and is attached to processor agreements (Stripe, AWS, Avalara, Checkr, Twilio already carry their own DPAs — this addendum governs Clinkit-side obligations and any future vendors).

1. Roles. Clinkit is the "business" (CCPA) / "controller" (GDPR-style) for buyer and Runner personal information; vendors are service providers/processors bound to process PI only per documented instructions, with confidentiality, security, sub-processor flow-down, and deletion-on-termination clauses. No vendor may sell or share PI or combine it across customers except as CCPA-permitted.

2. Data inventory (authoritative map — keep in sync with schema.sql).

Dataset	PI class	Store	Retention
users	identifiers, contact	Postgres <code>users</code>	life of account + 30d purge
runner_profiles	identifiers, financial (Stripe acct id), background-check status (sensitive)	Postgres	life of account + 30d
GPS trails	precise geolocation (sensitive)	<code>deliveries.gps_trail</code>	30 days post-delivery (purge job)
proof photos	visual	S3	180 days / dispute close
chat	comms	<code>messages</code>	90 days
payments	tokens only	Stripe (SAQ-A)	per Stripe
audit_log	admin actions	Postgres	2 years

3. Security measures (Annex). TLS 1.2+; AES-256 at rest; scrypt(N=16384) passwords; JWT 15-min access tokens; least-privilege IAM; secrets in AWS Secrets Manager; quarterly access review; audit log for admin reads of PI; pre-signed, content-type-pinned S3 uploads; rate limiting; dependency audit in CI.

4. Sensitive PI rules. Precise location and background-check results are used solely to provide the service and for safety — never for advertising. Access restricted to on-call ops with logged justification.

5. Incident response. Detect → contain → assess scope within 72h → notify affected individuals and regulators as required by state breach laws → post-mortem in ops runbook format. Contact chain in docs/ops/03-runbooks.md.

6. Data-subject requests. Routed through in-app self-service first (`/api/auth/me/export` , `DELETE /api/auth/me`); manual queue SLA 45 days; identity verification proportional to request sensitivity; log every request in `audit_log`.

7. Sub-processor register (launch). AWS (us-west-2), Stripe, Avalara, Checkr, Twilio, GitHub (code, no PI). Additions require this addendum's flow-down terms and a register update.